

TryHackMe

Offensive Security Intro

Learning Notes & Key Concepts

"To outsmart a hacker, you need to think like one."

1. What Is Offensive Security?

Offensive Security (OffSec) is the practice of proactively attacking systems in an authorized, controlled manner to find vulnerabilities before malicious actors do. Rather than waiting for attackers to strike, OffSec professionals think like hackers and simulate real-world attacks to expose weaknesses.

Core Principle

To defend a system effectively, you must first understand how it can be broken. Offensive security gives defenders the hacker's perspective, enabling them to build stronger, more resilient systems.

Offensive vs. Defensive Security

These two disciplines form the two pillars of cybersecurity:

Offensive Security	Defensive Security
Simulates attacks to find vulnerabilities	Monitors and protects systems from attacks
Proactive — finds flaws before attackers	Reactive — detects and responds to incidents
Includes: Pen Testing, Red Teaming	Includes: SOC, DFIR, Threat Intelligence
Exploits bugs in a controlled environment	Analyzes infected systems and malware

2. Key Concepts Covered

2.1 Penetration Testing

Penetration testing (pen testing) is a structured, authorized attempt to break into systems, applications, or networks to identify vulnerabilities and suggest mitigations. It answers the question: 'Can an attacker get in, and how far can they go?'

- Always requires explicit written permission from the asset owner.
- Operates within a defined scope — specific systems, timeframes, and methods.
- Results in a detailed report of findings and recommended remediations.
- Follows a methodology: Reconnaissance → Scanning → Exploitation → Post-Exploitation → Reporting.

2.2 Red Teaming

Red teaming is a full-scale, multi-layered adversarial simulation. Unlike pen testing, the defense team (Blue Team) is typically unaware that an engagement is in progress, making it a realistic test of detection and response capabilities.

- Simulates advanced persistent threats (APTs) and sophisticated attackers.
- Tests people, processes, and technology holistically — not just technical controls.
- Includes phishing, physical intrusion, and social engineering alongside technical attacks.
- Goal: Test how quickly and effectively the organization detects and responds to threats.

2.3 Vulnerability Research & Exploit Development

This involves reverse-engineering software to uncover flaws (bugs, logic errors, memory issues) and developing proof-of-concept exploits or patches. It forms the technical backbone of offensive security work.

- Often involves static analysis (reading code) and dynamic analysis (running code in controlled conditions).
- Leads to responsible disclosure — notifying the vendor before making findings public.
- Common vulnerability types: Buffer overflows, SQL injection, XSS, broken authentication.

2.4 Social Engineering

Social engineering exploits the human element — the weakest link in any security chain. Attackers deceive individuals into revealing information or performing actions that compromise security.

- Phishing: Deceptive emails tricking users into clicking malicious links or revealing credentials.
- Pretexting: Creating a fabricated scenario to manipulate a target.
- Vishing: Voice-based phishing over the phone.

3. Offensive Security Roles

The TryHackMe room introduces several career paths within offensive security. Each plays a distinct role in identifying and addressing cyber threats:

Role	Description	Key Attribute
Penetration Tester	Tests technology products to find exploitable vulnerabilities and report them.	Authorized, scoped, structured
Red Teamer	Simulates a full-scale adversary attack without alerting the defense team, testing detection and response.	Adversarial, covert, holistic
Security Engineer	Designs, monitors, and maintains security controls, networks, and systems to prevent attacks.	Preventive, architectural, ongoing
Vulnerability Researcher	Reverse-engineers software to uncover flaws and develop patches before exploitation.	Research-focused, technical, proactive

4. Hands-On Lab — FakeBank Website Hack

The room includes a practical exercise where learners legally hack a simulated banking website called FakeBank. This exercise demonstrates the real-world offensive security process end-to-end.

4.1 Tool Used: Gobuster

Gobuster is a command-line directory brute-forcing tool. It probes web servers with a wordlist to discover hidden pages and directories that are not linked publicly.

```
gobuster -u http://fakebank.thm -w wordlist.txt dir
```

- Gobuster systematically tries thousands of directory names against the target URL.
- Returns status codes — 200 means the page exists; 404 means it does not.
- Popular alternatives include dirb, dirbuster, and ffuf.
- A wordlist (like SecLists) is required — it contains common directory names to test.

4.2 Step-by-Step Attack Flow

Step	Action	What Was Learned
1	Launch the VM	TryHackMe uses browser-based Virtual Machines — no local setup required.
2	Run Gobuster	Discovered hidden /admin directory not linked on the public site.
3	Access /admin Page	Found an unauthenticated staff login portal — a critical misconfiguration.
4	Force Bank Transfer	Executed an unauthorized transfer between accounts, simulating real attacker impact.
5	Capture the Flag	Retrieved the success flag, confirming the attack chain was complete.

5. Key Takeaways & Lessons Learned

Think Like an Attacker

The most important mindset shift in offensive security is learning to view systems through an attacker's eyes. Every exposed endpoint, misconfigured service, or weak credential is a potential entry point.

Hands-On Practice is Essential

Reading about hacking techniques builds awareness, but doing it in a controlled lab environment builds real skill. Platforms like TryHackMe provide safe, legal environments to practice offensive techniques.

Tools Amplify Human Thinking

Gobuster, Nmap, Metasploit and similar tools automate tedious enumeration tasks — but they don't replace the analyst's judgment. Knowing what to do with findings is as important as finding them.

Web Servers Are High-Value Targets

Web applications are among the most attacked surfaces. Hidden admin panels, weak authentication, and improper access controls can have devastating consequences (as the FakeBank exercise demonstrated).

Authorization Is Non-Negotiable

Offensive security activities are only legal and ethical when explicitly authorized. Always obtain written permission, stay within agreed scope, and follow responsible disclosure principles.

Layered Security Is Critical

The FakeBank hack worked because multiple layers failed simultaneously: an exposed admin page, no authentication, and no alerting. Defence in depth ensures that one failure does not compromise everything.

6. Learning Path & Next Steps

Completing the Offensive Security Intro room is just the beginning. Here is a recommended progression for building deeper offensive security skills:

- **Immediate:** Complete TryHackMe's Introduction to Cyber Security learning path.
- **Foundations:** Work through the Pre-Security path to solidify networking and Linux fundamentals.
- **Intermediate:** Progress to the Jr Penetration Tester path on TryHackMe.
- **Certifications:** Study for certifications: CompTIA Security+, CEH, eJPT (beginner-friendly).
- **Advanced Practice:** Practice on HackTheBox, PortSwigger Web Security Academy for advanced labs.
- **Professional:** Work towards OSCP (Offensive Security Certified Professional) for professional recognition.

Consistency Is Key

You don't need to know everything on day one. Break cybersecurity down into small, daily practice sessions. Every room you complete on TryHackMe builds the knowledge and muscle memory needed to enter the field.

Summary

Topic	One-Line Summary
Offensive Security	Legally simulate attacks to find and fix vulnerabilities proactively.
Pen Testing	Structured, scoped attack to find exploitable weaknesses.
Red Teaming	Full adversarial simulation to test detection and response.

Social Engineering	Exploiting human psychology — the hardest vulnerability to patch.
Gobuster	Directory brute-forcer used to uncover hidden web paths.
FakeBank Lab	End-to-end attack: Discover → Access → Exploit → Capture flag.
Mindset	Think like an attacker; build better defences from the inside out.

Source: TryHackMe — Offensive Security Intro Room | tryhackme.com